

FTP Guide: Wireshark Analysis of FTP Traffic

What is FTP?

FTP (File Transfer Protocol) is a standard network protocol used to transfer files between a client and a server. It is one of the oldest protocols still in use today.

FTP uses two channels:

- **Control Channel** — Commands and responses (e.g., login, directory listing)
- **Data Channel** — Actual file transfer

FTP is **unencrypted by default**, making it excellent for learning packet analysis.

Typical Ports

- **TCP 21** — Control channel (commands, authentication)
- **TCP 20** — Active mode data channel (old)
- **High ephemeral ports** — Passive mode data channel (most common today)

Why Analysts Care About FTP

- Credentials are sent in **cleartext**.
- Files (including sensitive documents) are transferred in cleartext.
- Still widely used in legacy systems, embedded devices, and internal networks.
- Frequently targeted in attacks: brute force, credential sniffing, and data interception.

Wireshark Fundamentals for FTP Analysis

1. Basic Filtering

Bash

```
ftp                # All FTP control traffic
ftp.request        # FTP commands from client
ftp.response       # Server responses
tcp.port == 21     # Control channel
tcp.port == 20     # Active mode data
ftp contains "PASS" # Look for passwords
ftp contains "RETR" # File downloads
ftp contains "STOR" # File uploads
```

2. Key FTP Commands & Responses

Common Client Commands:

- **USER** — Username
- **PASS** — Password
- **LIST / NLST** — Directory listing

- RETR — Retrieve (download) a file
- STOR — Store (upload) a file
- CWD — Change Working Directory
- PWD — Print Working Directory
- TYPE — Set transfer type (ASCII or Binary)

Common Server Responses:

- 220 — Service ready
- 331 — Username OK, need password
- 230 — Login successful
- 227 — Entering Passive Mode (includes port info)
- 226 — Transfer complete
- 550 — Permission denied / file not found

Active vs Passive Mode

- **Active Mode:** Server initiates data connection back to client (port 20).
- **Passive Mode (PASV):** Client initiates data connection to a port provided by the server (most common).

In Wireshark you will often see the server respond with 227 Entering Passive Mode (h1,h2,h3,h4,p1,p2) — you can calculate the data port as $(p1 * 256) + p2$.

Common FTP Analysis Scenarios in Thaghrach Challenges

1. **Credential Sniffing**
 - Extract username and password from USER and PASS commands.
2. **File Transfer Reconstruction**
 - Identify which files were downloaded (RETR) or uploaded (STOR).
 - Export the actual file from the data channel.
3. **Directory Navigation**
 - Follow the user's navigation through CWD commands.
4. **Passive Mode Port Extraction**
 - Calculate and find the data connection port from 227 responses.
5. **Cleartext Sensitive Data**
 - Configuration files, scripts, or documents containing secrets.

Practical Workflow in Wireshark

1. Filter ftp to see the control channel.
2. **Follow** → **TCP Stream** on the control channel (port 21) to see the full command sequence.
3. Look for USER and PASS lines.
4. When you see a 227 Entering Passive Mode, note the port.
5. Filter the data channel: tcp.port == XXXX (the calculated port).
6. **Follow** → **TCP Stream** on the data channel to see file content.

7. **File** → **Export Objects** → **FTP-DATA** (Wireshark can automatically extract transferred files).

Security Red Flags in FTP Traffic

- Plaintext usernames and passwords.
- Transfer of sensitive file types (.db, .sql, .key, config files).
- Anonymous login (USER anonymous).
- Old FTP server versions in banners (e.g., vsftpd 2.3.4 — known vulnerabilities).
- Large file transfers to unexpected external IPs.

Example Challenge Goals You Will Encounter

- Capture the administrator's FTP password.
- Download and reconstruct the secret file transferred in the capture.
- Find the flag hidden inside a downloaded document.
- Identify both the control commands and the actual data transferred.
- Spot insecure FTP usage and suggest mitigations (use SFTP/FTPS instead).

Tips for Thaghras Students:

- Always analyze the **control channel (port 21)** first to understand what happened.
- Then locate the **data channel** for actual file content.
- Use **Export Objects** → **FTP-DATA** — it's a huge time saver.
- Remember: Everything in FTP is **readable** unless encrypted.